Insper

Avaliação Intermediaria Cybersegurança

João Eduardo Luisi

Criação de Plugin para Navegador Web Firefox para Bloqueio de Rastreadores

Objetivo: Criação de extensão para navegadores Firefox para detecção de ataques e violação de privacidade em cliente web.

Descrição: Desenvolver uma ferramenta capaz de detectar e apresentar:

- Conexões a domínios de terceira parte em uma navegação web;
- A quantidade de cookies injetados no carregamento de uma página;
- Detectar o armazenamento de dados (storage local) no cliente por intermédio do html5.
- Detectar sincronismo de cookies.

A insegurança dos Browsers

O navegador web, ou Browser,é o processo que fica a mais tempo em execução em um Sistema Operacional, sejapor motivos pessoais ou profissionais. Além deste detalhe os navegadores mais utilizados hoje são multiplataforma. Estas duas características chamam a atenção para que fraudadores busquem explorar vulnerabilidades de sistemas no elo mais fraco do ecossistema da tecnologia da informação, o usuário final.

Os browsers quando foram lançados exibiam apenas textos (ASCII e HTML) e imagens (GIF e JPEG). Devido às limitações da linguagem HTML (Hyper-Text Markup Language), logo surgiram alternativas para ampliar a capacidade do browser para torná-lo mais dinâmico e interativo. Uma das primeiras iniciativas neste sentido foi a adoção dos helpers (aplicativos auxiliares) que evoluíram para os atuais plug-ins[1].

Extensões de navegadores ou plug-ins, são programas executáveis que permitem ao browser executar arquivos em formatos diferentes de HTML, como áudio, animações e acesso a banco de dados. Um de seus pontos fracos é que sua confiança e segurança está depositada em quem o desenvolveu. O fato da extensão de navegador estar incorporada ao “core” do browser, ele utiliza o mesmo PID (Process ID), tendo assim acesso irrestrito ao seu sistema, comprometendo assim seu ambiente.

Com a introdução de linguagens/tecnologias como Java, JavaScript, VBscript e ActiveX, o browser passou a receber código ativo pela rede, ou seja, o simples fato de se visitar um site na Internet já é o suficiente para receber um código malicioso que possa ter acesso a qualquer parte do seu sistema (processador, memória, discos e rede) e, até mesmo, desligar sua estação[2].

Existem inúmeros motivos para uma aplicação client-server executar operações no lado cliente, tal como necessidade de acesso à informações ou funcionalidades que estão disponíveis em sua estação e não no servidor, poupar poder de processamento no servidor.

Garantir a segurança em clientes web é muito mais complexo do que no web server. Essa complexidade se dá devido a impossibilidade dos administradores do sistema gerenciarem de forma efetiva a segurança do dispositivo do usuários.

Browser hijacking

É a modificação não autorizada das configurações de um browser por um código malicioso, com o objetivo de ter acesso aos recursos do sistema ou também inserir anúncios indesejados. É muito comum que a instalação de plugins não confiáveis possa causar ações indesejadas pelo browser. Algumas são instaladas sem o consentimento do usuário.

Outra forma de sequestro de navegadores é por meio da exploração de uma falha de cross site scripting (XSS) em uma aplicação web. A falha de XSS pode permitir que um invasor utilize por exemplo o framework BeEF para injetar um código javas- cript dentro de uma página web vulnerável. A partir de sua execução no navegador, oinvasor poderá enviar comandos ao cliente infectado.

Entregáveis

Desenvolverum plugin para navegador capaz de detectar e apresentar:

- As conexões a domínios de terceira parte em uma navegação web;
- Potenciais ameaças de sequestro de navegador (hijacking e hook);
- Detectar o armazenamento de dados (storage local – html5) no dispositivo do usuário;
- A quantidade de cookies e supercookies injetados no carregamento de uma página (se possível diferencie em cookies de primeira e terceira parte, bem como sessão ou navegação);
- Detecção de Canvas fingerprint;
- Criar uma pontuação a partir de uma metodologia, indicando se a página respeita a privacidade do usuário.

1http://www.training.com.br/lpmaia/pub_seg_browser.htm

2http://www.training.com.br/lpmaia/pub_seg_browser.htm

Exemplo Prático:

- **Identificação de rastreadores:** Utilizar uma lista de domínios de rastreamento conhecida (ex: EasyList) e comparar com os hosts das requisições.
- **Bloqueio de conteúdo:** Interceptar as requisições para os domínios de rastreamento e cancelar o envio.
- **Personalização:** Permitir que o usuário crie listas personalizadas de domínios a serem bloqueados.
- **Interface:** Criar uma interface simples e intuitiva para o usuário configurar o plugin.

Conceito C (Nota C):

- Entregar todos os itens listados no item entregáveis.

Conceito B (Nota B):

- Interface Simples:
  Criar uma interface simples e intuitiva que permita gerenciar suas listas de domínio.
- Relatório Básico:
  Exibir um relatório simples na interface mostrando os rastreadores bloqueados durante a navegação.

Conceito A (Nota A):

- Identificação, Bloqueio e Personalização Completa:
  Além de cumprir os requisitos dos conceitos C e B, o plugin deve permitir personalização avançada, com a criação de listas de bloqueio, e a

capacidade de diferenciar entre domínios de rastreadores de primeira e terceira parte.

Indicação para pesquisa:

https://developer.mozilla.org/pt-BR/docs/Mozilla/Add-ons/WebExtensions/sua_primeira_WebExtension

https://developer.mozilla.org/pt-BR/Add-ons/WebExtensions/Passo-a-Passo

https://www.ibm.com/developerworks/br/library/os-extendchrome/index.html

https://addons.mozilla.org/en-US/firefox/user/miraculix200/

https://github.com/Miraculix200/StoragErazor

https://fingerprintable.org

https://addons.mozilla.org/pt-BR/firefox/addon/clear-storage-button/?src=api